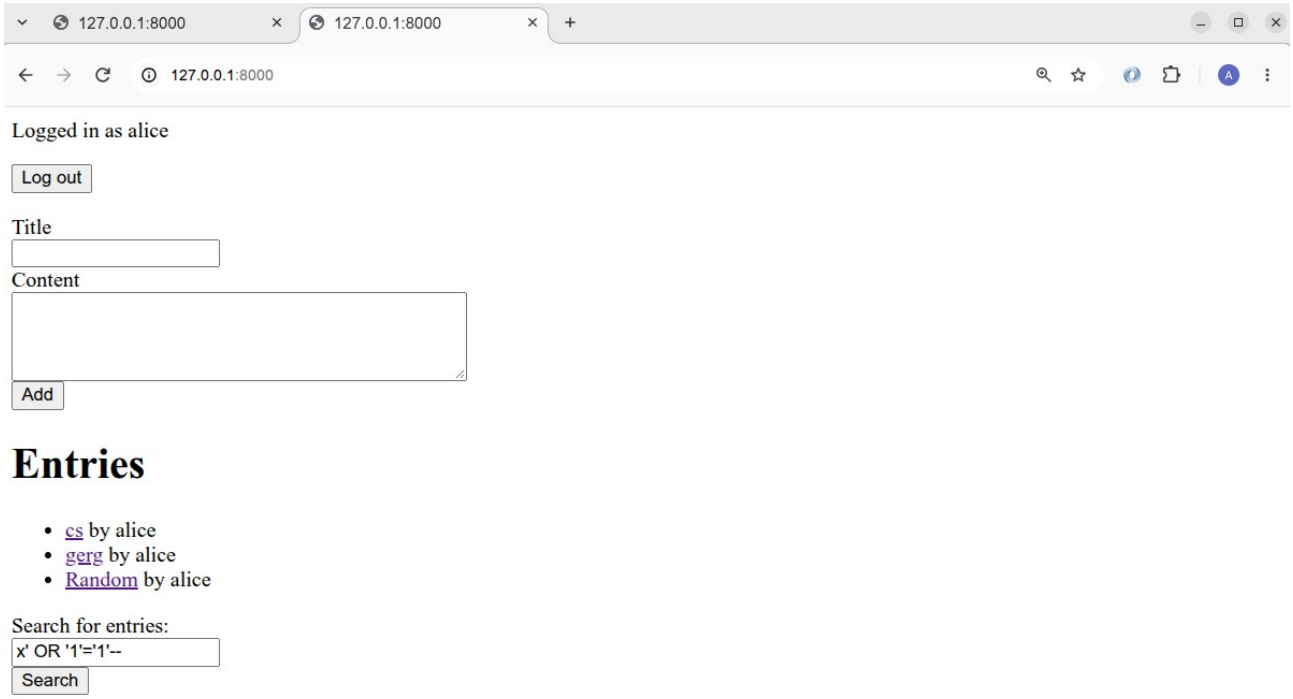
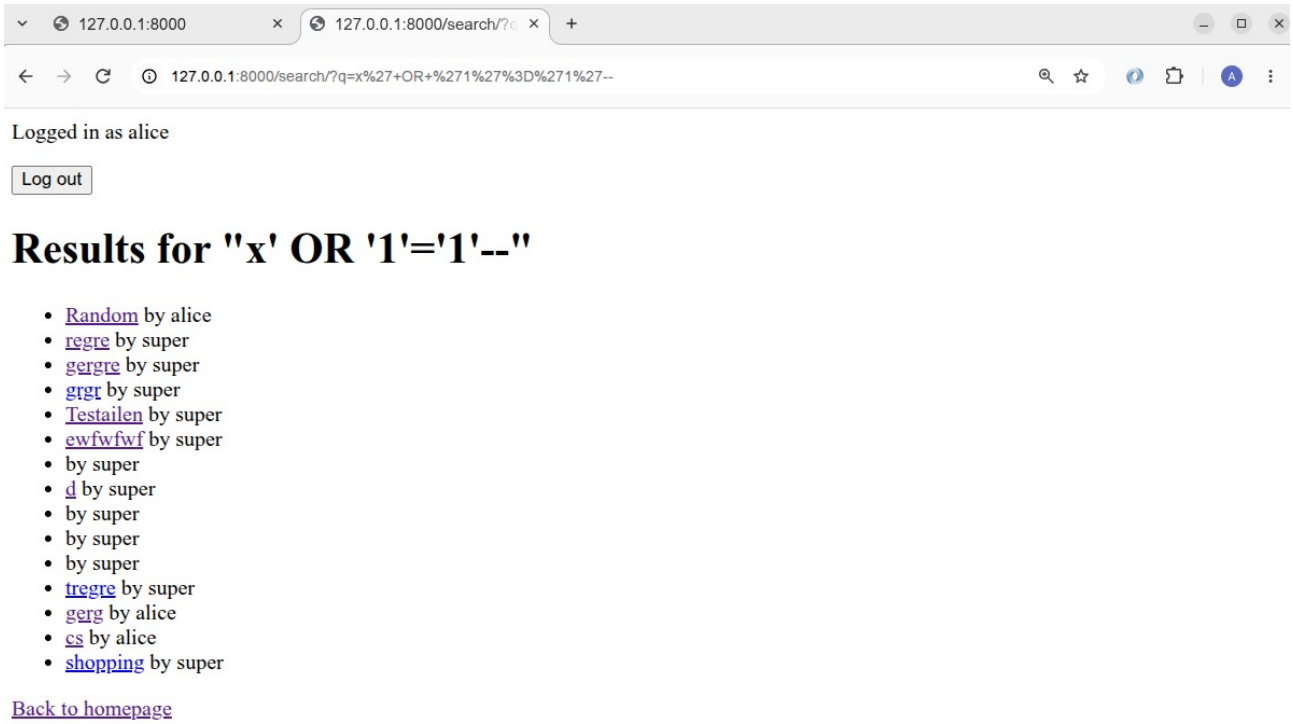


Logged in as alice, about to search for entries with “x' OR '1'='1'--” in the title.



Flawed state: because of SQL injection, the search input becomes part of the command, and all of the entries are shown.



Fixed state: search terms do not become part of the command, as the ORM sends the SQL command and the input to the database separately.